Informe OSINT: campaña de spam ArterioFlush

SpainCheck Pro · Análisis del 01/11/2026 · Correo recibido el 31/10/2026

> Análisis basado en fuentes abiertas (DNS, RDAP, certificados) y un único salto activo a través de Tor. Los indicadores están desactivados (hxxps, [.]) para evitar clics accidentales. El mensaje original se conserva en privado y no se publica.

Resumen ejecutivo

El 31/10/2026 llegó a un buzón personal un correo que suplanta a **CBS News** y al **doctor Oz** para vender un suplemento llamado «ArterioFlush». Usa testimonios falsos e insta a dejar la medicación antihipertensiva, lo que añade un **riesgo sanitario** al fraude comercial.

La infraestructura se reparte entre Namecheap, velia.net, Hivelocity, SERVERHUB y un pool de unas 30 IPs de hosters baratos. El hallazgo técnico más llamativo es un **registro CNAME mal escrito en la zona de comcast.net** que apunta a un dominio ajeno y permite falsear el DNS inverso (PTR) de ese pool de IPs.

No consta pérdida económica: no se pagó ni se introdujeron datos. No se resolvió el captcha de la página de destino, así que se desconoce la oferta final y el procesador de pago.

Cómo funciona el ataque (cadena de redirección)

1. El botón del correo enlaza a un fichero en Google Cloud Storage (hxxps://storage.googleapis[.]com/xcvdcxcd/nwdllrd.html) con un parámetro personalizado detrás de la almohadilla (#).
2. Ese fichero, de solo 107 bytes, ejecuta una línea de JavaScript que copia lo que hay tras la # y lo pega detrás de choracetamatoes[.]com. Como la # se resuelve en el navegador, un curl normal no sigue la cadena.
3. choracetamatoes[.]com (Apache 2.4.52, PHP 7.4.33) responde 200 con una página falsa de «Unsubscribe» que exige **reCAPTCHA**. Con un token inválido devuelve 404.
4. Tras el captcha estaría el destino real (la tienda del suplemento). No se obtuvo.

Por qué es útil para el atacante: alojar el redirector en Google Storage le da reputación de dominio de confianza, y el captcha impide que escáneres automáticos vean el destino final. El parámetro tras la # identifica a cada destinatario, por lo que conviene no abrir estos enlaces desde una conexión propia.

Cronología

Fecha	Hecho
12/04/2024	Registro de fluctance[.]net (Namecheap)
06/09/2024	Registro de choracetamatoes[.]com (Namecheap)
22/02/2025	Registro de comedgesuite[.]net (Namecheap)
23/05/2025	Registro de obesegrab[.]net (Namecheap)
20/08/2026	Certificado wildcard de choracetamatoes[.]com (Let's Encrypt)
29/10/2026	Subida del redirector al bucket de Google Storage
31/10/2026	Recepción del correo; el proveedor lo clasifica como spam
01/11/2026	Análisis pasivo y un salto activo por Tor

Indicadores de compromiso (IOCs)

Función	Indicador	Titular / proveedor	Notas
IP emisora	209.239.115[.]34	velia.net (bloque 209.239.112.0/20, cliente privado)	HELO obesegrab[.]net; PTR wholesale-vod-demo-1.comcast.net (falseado)
Dominio envelope	fluctance[.]net	Namecheap	Return-Path; A en 5.175.234[.]81

Función	Indicador	Titular / proveedor	Notas
Dominio HELO/SPF	obesegrab[.]net	Namecheap	SPF autoriza .34, .36 y .38; wildcard *.secured.obesegrab[.]net hacia .34
Tracker / landing	choracetamatoes[.]com (199.231.167[.]38)	Namecheap; Hivelocity	Puerta reCAPTCHA; MX en Google Workspace
Dominio del CNAME	comedgesuite[.]net (170.130.200[.]114)	Namecheap; SERVERHUB	Wildcard en el apex; sirve el pool de IPs
Redirector	hxxps://storage.googleapis[.]com/xcvdcxcd/nwdllrd.html	Google Cloud Storage	Subido el 29/10/2026
Imagen enlazada	hxxps://i[.]imgur[.]com/xPHiPxr.jpg	Imgur	Enlazada al tracker
From falso	mzqekgkjohmiqztsniuidjgp[.]com	No registrado (NXDOMAIN)	DKIM sin clave

Otros indicadores

- Site key de reCAPTCHA: `6Lf2Q_oUAAAAAPuHL-4TbwHMZajtdrTxLXEPfdeU` (útil para buscar otros dominios del mismo kit).
- Ruta de assets de la plantilla: `/assets/ayt/css/main.css`
- Token de verificación de Search Console del atacante: `JaDlI8P8VcFEh9nMSNhEFFjjxn8ubnvePXSsyO_Q18`

Hashes de la evidencia (SHA256)

Fichero	SHA256
Redirector (nwdllrd.html)	`0641a04a948dc1ca9915ee20d4f304e5b188966dbb60ec3969e6920a76bea804`
Página de destino (hop1.html)	`f87df3403bb98aceb5f3c1695c918deb02131da616d5c1e51048cb34212bea40`

Solo se publican los hashes de ficheros que son iguales para cualquier visitante. El mensaje original y las cabeceras de las peticiones se conservan en privado.

Pool de IPs con PTR falso de Comcast: unas 30 IPs repartidas entre Leaseweb, ColoCrossing/HostPapa, OVH, ISPpro, velia.net, SERVITRO, Starry Network, Hetzner, ServerPoint, MysticDev, gmhost y Contabo.

El truco del DNS inverso

El servidor autoritativo de Comcast (dns101.comcast.net) devuelve un CNAME de `wholesale-vod-demo-1.comcast.net` hacia `pmd205544tn.download.theplatform.comedgesuite.net`. Parece una errata en la zona (falta un punto al final), de modo que el nombre acaba colgando del dominio comedgesuite[.]net, que no es de Comcast y está registrado por un tercero. Resultado: cada IP del pool puede presentarse con un PTR que dice ser de Comcast, lo que da apariencia de legitimidad al enviar correo.

Confirmado frente a hipótesis

Lo confirmado procede de cabeceras, DNS y RDAP guardados. Las hipótesis no están verificadas y no deben citarse como hechos en una denuncia.

Confirmado

- El correo suplanta a CBS News y al doctor Oz, y desaconseja medicación antihipertensiva por nombre.
- La IP 209.239.115[.]34 envió el mensaje (SPF pass para el subdominio de fluctance[.]net; DKIM sin clave).
- El CNAME de Comcast apunta a comedgesuite[.]net, registrado el 22/02/2025 en Namecheap, que resuelve a unas 30 IPs; unas 25 tienen el PTR falso de Comcast.
- El redirector de Google Storage solo reenvía a choracetamatoes[.]com, que sirve un captcha.
- Cuatro dominios están en Namecheap con NS registrar-servers.com: choracetamatoes[.]com, fluctance[.]net, obesegrab[.]net y comedgesuite[.]net.

Hipótesis (sin verificar)

- El CNAME de Comcast es una errata que el operador aprovechó. Falta el histórico DNS para saber cuándo apareció y quién lo escribió.

- SERVITRO LTD (AS213495) podría ser del operador o muy cercano: comparte el /24 5.175.234.0/24 con fluctance[.]net y su AS se creó un mes antes que comedgesuite[.]net.
- Las IPs del pool pueden ser servidores del operador o clientes de hosters con un rDNS ajeno. Solo la .34 consta como emisora.
- 170.130.200[.]114 solo consta como host de correo de comedgesuite[.]net; no hay spam enviado desde ella.
- La cabecera X-Google-Sender-Delegation parece inyectada por el spammer para ganar confianza; no está en la firma DKIM.
- Compartir registrador (Namecheap) y fechas es una pista débil, porque es un registrador muy grande.

Nota: el bloque final del correo, con marcas como Enterprise, YNAB, IBM, Podio, Fastly o Parsec, es relleno anti-Bayes. Esas marcas no están implicadas. No hay vínculo con otros casos del repositorio: ni las IPs ni los ASN del pool coinciden.

Notificaciones

A 01/11/2026 los reportes están redactados y pendientes de envío. El orden propuesto prioriza a quien puede cortar el DNS y el envío.

Orden	Destinatario	Objeto	Estado
1	Namecheap	4 dominios	Redactado, pendiente de envío
2	Comcast (canal de seguridad)	CNAME erróneo en comcast.net	Redactado, pendiente de envío
3	velia.net	209.239.115[.]34 y 92.204.97[.]212	Redactado, pendiente de envío
4	Hivelocity	199.231.167[.]38	Redactado, pendiente de envío
5	SERVERHUB / Eonix	170.130.200[.]114	Redactado, pendiente de envío
6	INCIBE-CERT	Campaña completa con cabeceras	Pendiente
7	Google Cloud	Bucket xcvdcxcd	Pendiente
8	Imgur	Imagen enlazada	Pendiente
9	Hosters del pool	IPs con PTR falso	Opcional; evidencia más débil

Qué aprender de este caso

- Los redirectores en nubes de confianza (Google Storage) esquivan filtros por reputación.
- El # en la URL se resuelve en el navegador: por eso un curl no basta y hay que leer el HTML.
- Un PTR no es prueba de identidad: un CNAME mal puesto en una zona ajena puede falsearlo.
- El spam sanitario que insta a dejar medicación es un riesgo real, no solo una molestia.